



North Sails Vulnerability Assessment and Config Audit Report

UK Portsmouth Firewall

CONFIDENTIAL



DO NOT COPY OR DO NOT RELEASE FOR PUBLIC
REVIEW

N-ABLE (PVT) LTD

36, Bristol Street, Colombo 01, Sri Lanka.

PRIVATE & CONFIDENTIAL

Status: FINAL

Version: 1.1

Issue Date: 25/06/2026

Document Type: CONFIDENTIAL

This publication has been prepared and written by N*able (Pvt) Ltd. and is subject to copyright. Other than for the purpose of and subject to the conditions prescribed under the Copyright Act, no part of it may in any form or by any means (electronic, mechanical, micro copying, photocopying, or otherwise) be reproduced, stored in a retrieval system, or transmitted without prior written permission from the document controller. Product or company names are trademarks or registered trademarks of their respective holders.



Contents

1 Document Information	3
1.1 Author	3
1.2 File Information.....	3
1.3 Summary of Changes.....	3
1.1 Review and Approval.....	4
1.2 Assessment Details.....	5
2 Introduction	6
2.1 Executive Summary	6
2.2 Audience.....	7
2.3 Reference.....	7
2.4 Severity Ratings	8
2.5 Scope	9
2.6 Report Summary.....	10
2.7 Vulnerability Risk Calculation for the Asset.....	11
2.8 Vulnerability Risk Calculation for the Asset.....	12
2.9 Scan Results	13
2.9.1 Scan Results – 174.67.65.125.....	13
2.10 Host By Vulnerabilities.....	14
2.11 Host by Compliances.....	44
3 Document Acceptance Certificate	80

1 Document Information

1.1 Author

Organization	Name	Title	E-mail
N-Able (Pvt) Ltd	Dulan Rathnayaka	Engineer – Info Sec	dulanr@n-able.biz

1.2 File Information

File name	North Sails Vulnerability Assessment and Config Audit Report
Customer	North Sails PVT
Project	Security Audit and Security Awareness Program 2026
Location	UK Portsmouth
Application	
Note	
Reference No	

1.3 Summary of Changes

Issue Date	Version	Document Changes	Modified By
25/06/2026	1.0	Initial	Dulan
30/06/2026	1.1	Modify	Lakmi

1.1 Review and Approval

This document has been reviewed by the following:

Reviewer	Role	Date	Review Comment
Lakmi Nanayakkara	Senior Engineer – Information Security	02/07/2026	
Prabuddha Deshan	Lead Engineer – Information Security	03/07/2026	
Asanka Sanjeewa Abeyrathne	Head of Technology - Information Security	03/07/2026s	

1.2 Assessment Details

This document presents the Vulnerability Assessment report for the Firewall deployed in the North Sails site in Portsmouth, UK. As per the request, this assessment covers one device. The vulnerability assessment was performed based on authenticated scans. This report provides a comprehensive overview of the vulnerabilities identified during the assessment and outlines recommended remediation measures for each identified vulnerability.

2 Introduction

2.1 Executive Summary

This document presents a detailed report on the Vulnerability Assessment (VA) conducted by N-able for North Sails. The assessment encompassed the entirety of the Client's IT infrastructure landscape. The primary objective was to strengthen the security and resilience of the Client's IT systems, services, and platforms. The Vulnerability Assessment identified a total of **three Critical-severity vulnerabilities, seven high-severity vulnerabilities, seventeen medium-severity vulnerabilities, and three low-severity** vulnerabilities of the device under the device type "Firewall". Addressing these critical, high, medium, and low-severity vulnerabilities is crucial for maintaining a resilient security framework. As all identified vulnerabilities are associated with known issues in the current FortiOS version, it is recommended to follow the upgrade path below to remediate these findings.

1. Upgrade the FortiGate device to FortiOS 7.2.13 (M), Build 1762.
2. Subsequently, upgrade to FortiOS 7.4.12 (M), Build 2902.

Following this upgrade path will ensure that the device is running a version that addresses the identified vulnerabilities and aligns with Fortinet's recommended upgrade sequence.

A compliance assessment evaluated the IT Infrastructure's adherence to CIS FortiGate 7.4. x v1.0.1 Benchmark. Overall, the compliance assessment identified **eighteen passed** compliances and **twenty-two failed** compliance items. Addressing the failed compliances is important to strengthen the cybersecurity posture of the IT Infrastructure landscape.

The recommendations, as detailed in the full report, provide clear guidance on how to remediate these identified vulnerabilities. Prompt attention to these recommendations is essential to integrate them into the Company's ongoing

security practices. The North Sails PVT commitment to vulnerability assessments underscores its proactive stance towards ensuring the security and protection of its IT systems, services, and infrastructure. This approach aligns with industry best practices in information security and serves as a safeguard against potential general and specific threats in today's ever-evolving digital landscape.

For an in-depth breakdown of the identified vulnerabilities and the corresponding remediation steps, please refer to the complete Vulnerability Assessment report.

2.2 Audience

This document is intended to be used by the North Sails PVT and N-Able teams who are involved in the solution rollout process.

2.3 Reference

<https://www.tenable.com>

<https://cve.mitre.org/>

2.4 Severity Ratings

The following table defines levels of severity that are used throughout the document to assess vulnerability and risk impact:

CRITICAL	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
HIGH	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as
MEDIUM	Findings which are a result of poor implementation of controls and recommendations with medium priority include areas requiring improvements.
LOW	Findings and recommendations with low priority include areas to enhance controls or improve efficiencies.
INFO	Informational vulnerabilities are vulnerabilities that provide specific bits of information to the end-user that were not designed to be released, yet have no specific security

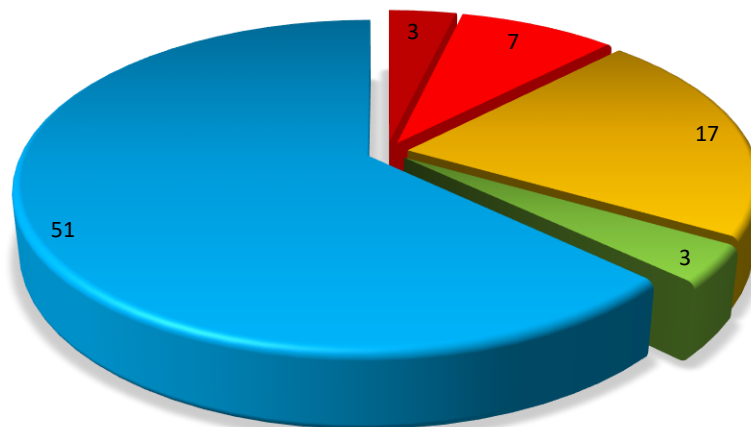
2.5 Scope

DEVICE TYPE and BRAND	DEVICE MODEL	HOSTNAME	IP ADDRESS
FortiGate	FortiGate 90G	GBR-NS-POS	174.67.65.125

2.6 Report Summary

IP ADDRESS	CRITICAL	HIGH	MEDIUM	LOW	INFO
174.67.65.125	3	7	17	3	51

Vulnerabilities



2.7 Vulnerability Risk Calculation for the Asset

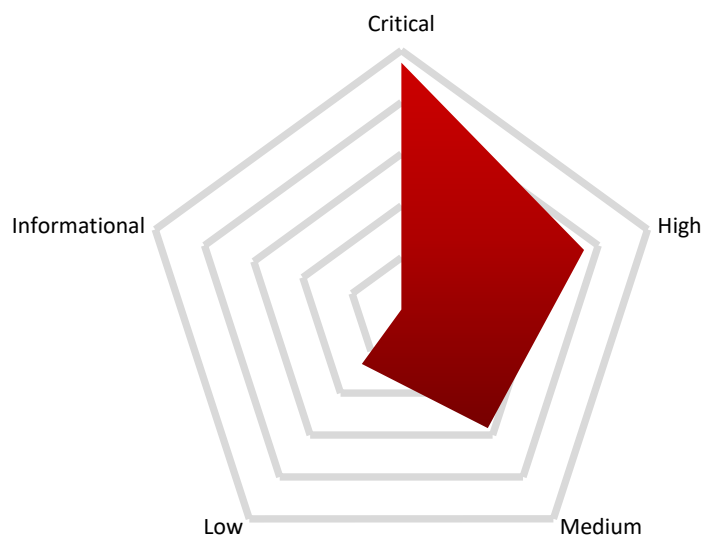
Risk Calculation Methodology:

The report uses a structured methodology to prioritize and quantify asset security posture risks.

Components of the Risk Equation:

1. **Asset Severity:** A scale of 1 to 5 is employed to assess the asset, where the highest criticality is indicated by 5.
2. **CVSS Base Score:** CVSS Base score Values that are assigned for each vulnerability.
3. **Number of Vulnerabilities:** The total number of vulnerabilities identified for the asset under the levels Critical, High, Medium, and Low.

Risk Score for the Assets:



126.1%

45% ≤  70% ≤  90% ≤  100% ≤ 

2.8 Vulnerability Risk Calculation for the Asset

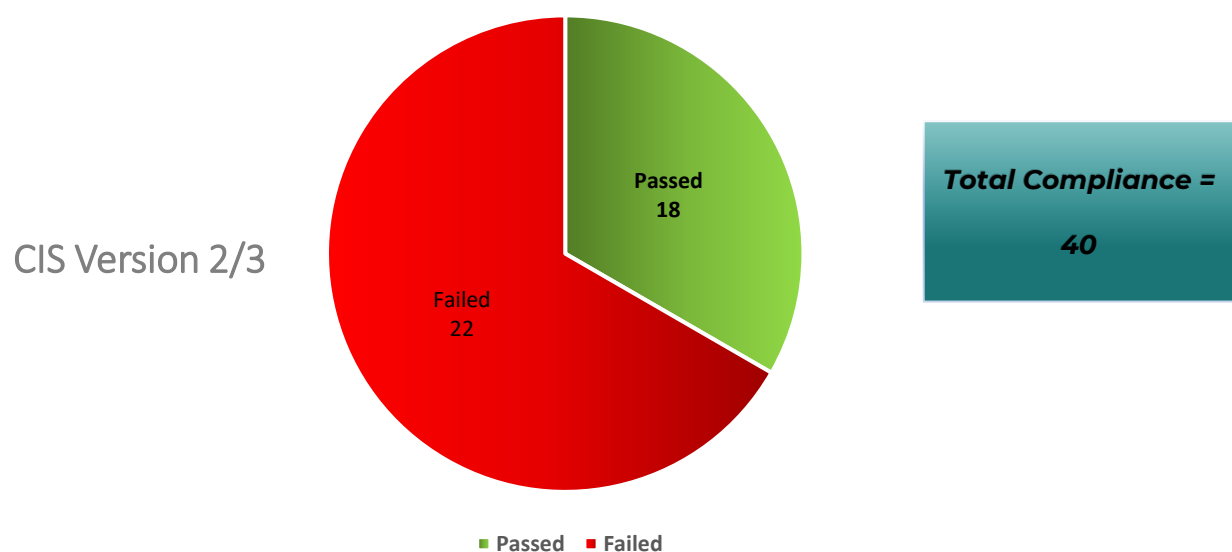
Risk Calculation Methodology:

The report uses a structured methodology to prioritize and quantify asset security posture risks.

Components of the Risk Representation:

1. **Number of Failed Compliances:** The number of failed compliances matches the organization's use case.
2. **Number of Compliances:** The total number of compliances given by the CIS benchmark version 2/3.

Compliance Score for the Assets:



2.955Scan Results

2.9.1 Scan Results – 174.67.65.125

Authenticated Firewall Scan

Host	GBR-NS-POS (174.67.65.125)
Scanned Date	24/06/2026
Identified OS	FortiOS 7.2.10

Vulnerabilities:



Compliances:



2.10 Host By Vulnerabilities

01 Fortinet FortiGate – Heap-Based Buffer Overflow in cw_acd Daemon (FG-IR-25-084)

Critical

Description

The installed version of FortiOS is affected by a Heap-Based Buffer Overflow vulnerability (CWE-122) in the cw_acd daemon, tracked as CVE-2025-25249. A remote unauthenticated attacker may trigger the overflow by sending specially crafted packets, potentially enabling the execution of arbitrary code or commands on the affected device.

Impact

Successful exploitation could result in complete compromise of the affected FortiGate device, with significant impact across confidentiality, integrity, and availability. As no authentication is required, this vulnerability is particularly critical for internet-facing deployments and represents one of the higher-severity findings in this assessment.

PoC

```
Installed version : 7.2.10
Fixed version    : 7.2.12
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.12 or above. The system can be upgraded to FortiOS 7.2.12. Please note if upgrading be caution on the services that are currently running in the environment.

02 Fortinet FortiGate – RADIUS Protocol Forgery Vulnerability / BlastRADIUS (FG-IR-24-255)

Critical

Description

The RADIUS protocol implementation in the affected version of FortiOS is susceptible to CVE-2024-3596 (known as BlastRADIUS), an industry-wide protocol-level flaw in RFC 2865. A network-adjacent attacker positioned between the RADIUS client and server may exploit a chosen-prefix collision attack against the MD5-based Response Authenticator to forge any valid RADIUS response — including converting an Access-Reject to an Access-Accept — without detection by either party.

Impact

Successful exploitation could allow a man-in-the-middle attacker to bypass RADIUS-based network authentication entirely, granting unauthorized access to network resources or escalating privileges on systems that rely on RADIUS for authentication. Given the protocol-level nature of this flaw, all FortiOS deployments using RADIUS/UDP or RADIUS/TCP for authentication are potentially affected until both the FortiOS upgrade and Message-Authenticator enforcement are applied.

PoC

```
Installed version : 7.2.10
Fixed version      : 7.2.11
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.11 or above. The system can be upgraded to FortiOS 7.2.11. Please note if upgrading be caution on the services that are currently running in the environment.

03 Fortinet FortiGate – FortiCloud SSO Login Authentication Bypass (FG-IR-25-647)

Critical

Description

The installed version of FortiOS is affected by an Improper Verification of Cryptographic Signature vulnerability (CWE-347), tracked as CVE-2025-59718. This may allow an unauthenticated attacker to bypass the FortiCloud SSO login authentication via a crafted SAML message, if that feature is enabled on the device.

Impact

Successful exploitation grants unauthenticated remote administrative access to the affected device, enabling unauthorized configuration changes, account creation, VPN manipulation, and credential exfiltration. Rated Critical (CVSS 3.1:9.8), this vulnerability is confirmed exploited in the wild and listed in the CISA Known Exploited Vulnerabilities catalog immediate remediation is warranted.

PoC

```
Installed version : 7.2.10
Fixed version    : 7.2.12
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.12 or above. The system can be upgraded to FortiOS 7.2.12. Please note if upgrading be caution on the services that are currently running in the environment.

01 Fortinet FortiGate – Authenticated Heap Overflow in SSL-VPN Bookmarks (FG-IR-25-756)

High

Description

The installed version of FortiOS is affected by a Heap-Based Buffer Overflow vulnerability (CWE-122) in the SSL-VPN RDP bookmark connection feature, tracked as CVE-2025-57740. An authenticated attacker may trigger the overflow via specially crafted requests during an RDP bookmark session, potentially enabling execution of unauthorized code on the affected device.

Impact

Successful exploitation could allow an authenticated attacker to execute arbitrary code with the privileges of the affected process, resulting in significant risk to the confidentiality, integrity, and availability of the device. While authentication is required, this vulnerability is remotely exploitable and carries High severity, warranting priority remediation.

PoC

```
Installed version : 7.2.10  
Fixed version    : 7.2.11
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.11 or above. The system can be upgraded to FortiOS 7.2.11. Please note if upgrading be caution on the services that are currently running in the environment.

02 Fortinet FortiGate – Format String Vulnerability in CAPWAP Fast-Failover Mode (FG-IR-25-795)

High

Description

The installed version of FortiOS is affected by the Use of Externally-Controlled Format String vulnerability (CWE-134) in the CAPWAP fast-failover mode CLI component, tracked as CVE-2025-64157. An authenticated administrator may exploit this flaw through specially crafted configuration input to execute unauthorized code or commands on the affected device.

Impact

Successful exploitation could allow an authenticated administrator to execute arbitrary code, potentially enabling unauthorized modifications to device operations beyond their intended administrative scope. While administrative privileges are required, this vulnerability poses a risk in environments where multiple administrator accounts are present or where credential compromise is a concern.

PoC

```
Installed version : 7.2.10  
Fixed version    : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4.10 or above. The system can be upgraded to FortiOS 7.4.10. Please note if upgrading be caution on the services that are currently running in the environment.

03 Fortinet FortiGate – Heap Overflow in fgfmsd Daemon (FG-IR-24-442)

High

Description

The installed version of FortiOS is affected by a Heap-Based Buffer Overflow vulnerability (CWE-122) in the fgfmsd daemon, which handles FortiGate-to-FortiManager (FGFM) protocol communications, tracked as CVE-2024-50571. An authenticated attacker may trigger the overflow via specially crafted requests, potentially enabling arbitrary code execution within the context of the affected daemon process.

Impact

Successful exploitation could allow an authenticated attacker to execute arbitrary code on the affected device, with potential impact to the confidentiality, integrity, and availability of the system and its managed network infrastructure. Given the role in centralized management communications, exploitation may also affect interconnected FortiManager and FortiAnalyzer components.

PoC

```
Installed version : 7.2.10  
Fixed version    : 7.2.11
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.11 or above. The system can be upgraded to FortiOS 7.2.11. Please note if upgrading be caution on the services that are currently running in the environment.

04 Fortinet FortiGate – Incorrect Privilege Assignment in Security Fabric (FG-IR-25-173)

High

Description

The installed version of FortiOS is affected by an Incorrect Privilege Assignment vulnerability (CWE-266) in the Security Fabric component, tracked as CVE-2025-53744. This flaw may allow a remote authenticated attacker with high-level privileges to escalate their access to super-admin by registering the affected device to a maliciously controlled FortiManager instance.

Impact

Successful exploitation could grant an attacker complete super-administrative control over the FortiGate device, enabling unauthorized modification of security policies, firewall configurations, and network access controls. Given that proof-of-concept exploit code has been observed publicly, this vulnerability carries elevated operational risk. A compromised super-admin account could undermine the integrity of the entire network security infrastructure managed by the affected device.

PoC

```
Installed version : 7.2.10  
Fixed version    : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4.8 or above. The system can be upgraded to FortiOS 7.4.8. Please note if upgrading be caution on the services that are currently running in the environment.

05 Fortinet FortiGate – PKI via API Authentication Bypass with Invalid Certificate (FG-IR-24-511)

High

Description

The installed version of FortiOS is affected by a Missing Critical Step in Authentication vulnerability (CWE-304), tracked as CVE-2024-52965. FortiOS fails to fully validate the PKI user certificate during API key + PKI combined authentication, allowing an API user to successfully authenticate and gain access even when presenting an invalid certificate.

Impact

Successful exploitation allows an attacker in possession of a valid API key to bypass PKI certificate validation, undermining a key layer of multi-factor API authentication. This may result in unauthorized administrative API access to the affected device, with potential high impact to confidentiality, integrity, and availability of the managed network infrastructure.

PoC

```
Installed version : 7.2.10
Fixed version    : 7.2.11
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.11 or above. The system can be upgraded to FortiOS 7.2.11. Please note if upgrading be caution on the services that are currently running in the environment.

06 Fortinet FortiGate – Restricted CLI Command Bypass (FG-IR-24-361)

High

Description

The installed version of FortiOS is affected by an Incorrect Provision of Specified Functionality vulnerability (CWE-684) in the CLI component, tracked as CVE-2025-58325. A local authenticated attacker may craft specific CLI commands to bypass intended command restrictions and execute unauthorized system-level commands via the Broadcom (BCM) shell. This vulnerability affects specific FortiGate hardware platforms only; other models are not affected.

Impact

Successful exploitation enables a locally authenticated attacker to escalate privileges and execute arbitrary system commands beyond their authorized scope, potentially resulting in full device compromise. While local access and existing credentials are required, the low attack complexity and high impact across confidentiality, integrity, and availability represent a significant risk in environments with multiple CLI users or shared administrative access.

PoC

```
Installed version : 7.2.10  
Fixed version    : 7.2.11
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.11 or above. The system can be upgraded to FortiOS 7.2.11. Please note if upgrading be caution on the services that are currently running in the environment.

07 Fortinet FortiGate – ZTNA Server Improper Certificate Validation (FG-IR-24-457)

High

Description

The installed version of FortiOS is affected by an Improper Validation of Certificate with Host Mismatch vulnerability (CWE-297) in FortiOS may allow an unauthenticated attacker in a man-in-the middle position to intercept and tamper with connections to the ZTNA proxy.

Impact

Exploitation of this vulnerability can allow an unauthenticated attacker to silently intercept and manipulate traffic passing through the ZTNA proxy, effectively undermining the Zero Trust access model the component is designed to enforce. This poses a direct risk to the confidentiality and integrity of communications between remote users and protected internal resources and may expose sensitive application data or authentication material to unauthorized parties.

PoC

```
Installed version : 7.2.10  
Fixed version    : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4.9 or above. The system can be upgraded to FortiOS 7.4.9. Please note if upgrading be caution on the services that are currently running in the environment.

01 Fortinet FortiGate – DNS Type 65 Resource Record Requests Bypass DNS Filter (FG-IR-24-053)

Medium

Description

The installed version of FortiOS is affected by an Improperly Implemented Security Check vulnerability (CWE-358), tracked as CVE-2024-55599. The FortiOS DNS filter fails to correctly inspect or enforce policy against DNS type 65 (HTTPS) resource record queries, which are natively used by Apple devices, allowing a remote unauthenticated user to bypass configured DNS filtering controls.

Impact

Successful exploitation enables unauthenticated users on Apple devices to circumvent DNS-based content filtering and security policies, potentially accessing restricted or malicious domains that would otherwise be blocked. This undermines the effectiveness of DNS filtering as a network-layer security control, particularly in environments with a significant Apple device footprint.

PoC

```
Installed version : 7.2.10  
Fixed version    : 7.2.11
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.11 or above. The system can be upgraded to FortiOS 7.2.11. Please note if upgrading be caution on the services that are currently running in the environment.

02 Fortinet FortiGate – Heap Buffer Overflow in WebSocket (FG-IR-24-546)

Medium

Description

The installed version of FortiOS is affected by a Heap-Based Buffer Overflow vulnerability (CWE-122) in the Node.js WebSocket component of the GUI interface, tracked as CVE-2025-22258. An authenticated attacker may exploit this flaw via specially crafted HTTP requests to escalate privileges or execute arbitrary code within the context of the affected daemon.

Impact

Successful exploitation could allow an authenticated attacker to escalate privileges on the affected device, with high impact to confidentiality, integrity, and availability. While high-level privileges are required to exploit this vulnerability, compromise of the Node.js WebSocket component represents a significant risk given its role in GUI-based management communications.

PoC

```
Installed version : 7.2.10  
Fixed version    : 7.2.11
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.11 or above. The system can be upgraded to FortiOS 7.2.11. Please note if upgrading be caution on the services that are currently running in the environment.

03 Fortinet FortiGate – Insufficient Session Expiration in SSL-VPN Cookie (FG-IR-24-339)

Medium

Description

The installed version of FortiOS is affected by an Insufficient Session Expiration vulnerability (CWE-613) in the SSL-VPN web portal component, tracked as CVE-2024-50562. An attacker in possession of a captured SSL-VPN session cookie (specifically the SVPNTMPCOOKIE) may replay it to re-authenticate to the portal even after the session has been explicitly logged out or expired. This vulnerability affects SSL-VPN portal/web mode only; tunnel mode is not affected.

Impact

Successful exploitation could allow an attacker who has obtained a valid session cookie — through interception or credential theft to maintain unauthorized access to the SSL-VPN portal beyond session termination, bypassing logout as a security control. A public proof-of-concept exploit is available, increasing the likelihood of exploitation in the wild.

PoC

```
Installed version : 7.2.10
Fixed version    : 7.2.11
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.11 or above. The system can be upgraded to FortiOS 7.2.11. Please note if upgrading be caution on the services that are currently running in the environment.

04 Fortinet FortiGate – Integer Overflow in SSL-VPN Bookmarks (FG-IR-24-364)

Medium

Description

The installed version of FortiOS is affected by an Integer Overflow or Wraparound vulnerability (CWE-190) in the SSL-VPN RDP and VNC bookmark components, tracked as CVE-2025-25248. An authenticated attacker may trigger the integer overflow condition via specially crafted requests, causing a Denial of Service (DoS) condition that disrupts SSL-VPN availability.

Impact

Successful exploitation could allow an authenticated attacker to disrupt SSL-VPN service availability, preventing legitimate users from establishing remote access connections. While the impact is confined to availability and requires authentication, repeated exploitation could significantly impair business continuity for environments dependent on SSL-VPN for remote access.

PoC

```
Installed version : 7.2.10  
Fixed version    : 7.2.11
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.11 or above. The system can be upgraded to FortiOS 7.2.11. Please note if upgrading be caution on the services that are currently running in the environment.

05 Fortinet FortiGate – Privilege Escalation in GUI WebSocket Module (FG-IR-25-006)

Medium

Description

The installed version of FortiOS is affected by an Improper Privilege Management vulnerability (CWE-269) in the GUI Node.js WebSocket module, tracked as CVE-2025-22254. An authenticated attacker with at minimum read-only administrative permission may send specially crafted WebSocket requests to escalate their privileges to super-admin level, bypassing intended role-based access controls.

Impact

Successful exploitation grants a low-privileged authenticated attacker complete super-administrative control over the FortiGate device, enabling unrestricted modification of security policies, firewall configurations, and administrative accounts. This significantly undermines access control integrity, particularly in environments where read-only or limited administrator accounts are shared across operational teams.

PoC

```
Installed version : 7.2.10
Fixed version      : 7.2.11
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.11 or above. The system can be upgraded to FortiOS 7.2.11. Please note if upgrading be caution on the services that are currently running in the environment.

06 Fortinet FortiGate – Restricted CLI Escape Using Lua (FG-IR-26-143)

Medium

Description

The installed version of FortiOS is affected by an Internal Asset Exposed to Unsafe Debug Access Level vulnerability (CWE-1244), tracked as CVE-2025-67862. An authenticated administrator may exploit an exposed Lua scripting interface accessible via crafted CLI commands to escape the restricted CLI environment and execute arbitrary Lua scripts outside the intended operational boundary.

Impact

Successful exploitation could allow an authenticated administrator to bypass CLI restrictions and execute unauthorized code, potentially enabling actions beyond their sanctioned administrative scope on the affected device. While local access and existing administrative credentials are required, this vulnerability represents a risk in environments where CLI access is granted to multiple administrator accounts with varying trust levels.

PoC

```
Installed version : 7.2.10  
Fixed version    : 7.2.11
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.11 or above. The system can be upgraded to FortiOS 7.2.11. Please note if upgrading be caution on the services that are currently running in the environment.

07 Fortinet FortiGate – Stack-Based Buffer Overflow in CLI Import Feature (FG-IR-23-354)

Medium

Description

The installed version of FortiOS is affected by a Stack-Based Buffer Overflow vulnerability (CWE-121) in the CLI import feature, tracked as CVE-2023-46718. An authenticated attacker may trigger the overflow via specially crafted CLI commands, potentially enabling the execution of arbitrary code or unauthorized commands on the affected device.

Impact

Successful exploitation could allow an authenticated local attacker to execute arbitrary code with high impact to the confidentiality, integrity, and availability of the affected device. While local access and elevated privileges are prerequisites, exploitation may enable complete device compromise and facilitate lateral movement within the network environment.

PoC

```
Installed version : 7.2.10  
Fixed version    : 7.2.12
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.12 or above. The system can be upgraded to FortiOS 7.2.12. Please note if upgrading be caution on the services that are currently running in the environment.

08 SSL Certificate Cannot Be Trusted /SSL Certificate Expiry/ SSL Self-Signed Certificate

Medium

Description

The server's X.509 certificate on TCP port 443 cannot be trusted. This is due to Fortinet shipping a default Fortinet self-signed certificate with FortiGate firewalls. The reason why is the certificate promoted as cannot be trusted/self-signed is the top of the certificate chain is not descended from a known public certificate authority and the certificate chain may contain a signature that cannot be verified, since there is no way to guarantee the legitimacy of self-signed certificates. Furthermore, the self-signed certificate installed is also expired.

Impact

If the remote host is a public host in production, any break in the chain makes it more difficult for users to verify the authenticity and identity of the web server. This could make it easier to carry out man-in-the-middle attacks against the remote host.

PoC

```
The SSL certificate has already expired :
```

```
Subject      : O=Fortinet Ltd., CN=FortiGate
Issuer       : O=Fortinet Ltd., CN=FortiGate
Not valid before : Feb 28 14:17:36 2024 GMT
Not valid after  : Jun  2 14:17:36 2026 GMT
```

```
The following certificate was at the top of the certificate
chain sent by the remote host, but it is signed by an unknown
certificate authority :
```

```
|-Subject : O=Fortinet Ltd./CN=FortiGate
|-Issuer  : O=Fortinet Ltd./CN=FortiGate
```

Remediation

Install a valid SSL certificate purchased from a certificate authority. If a wild card SSL certificate has been purchased for the organization domain, install the specific certificate.

09 Fortinet FortiGate – HTTP Request Smuggling in FortiOS (FG-IR-25-667)

Medium

Description

The installed version of FortiOS is affected by an HTTP Request Smuggling vulnerability (CWE-444), tracked as CVE-2025-55018, which arises from inconsistent interpretation of HTTP headers within the FortiOS GUI. This flaw may allow an unauthenticated attacker to smuggle malformed HTTP requests through firewall policies without generating log entries.

Impact

Successful exploitation enables an unauthenticated attacker to bypass configured firewall policies and evade audit logging, allowing malicious traffic to reach protected resources undetected. This directly undermines the organization's security monitoring posture and may compromise compliance obligations requiring complete traffic audit trails.

PoC

```
Installed version : 7.2.12  
Fixed version    : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4.10 or above. The system can be upgraded to FortiOS 7.4.10. Please note if upgrading be caution on the services that are currently running in the environment.

10	Fortinet FortiGate – Firewall Policy Bypass in FSSO Terminal Services Agent (FG-IR-25-384)	Medium
----	--	--------

Description

The installed version of FortiOS is affected by an Improper Verification of Source of a Communication Channel vulnerability (CWE-940) in the Fortinet Single Sign-On (FSSO) Terminal Services Agent, tracked as CVE-2025-62439. An authenticated user with knowledge of FSSO policy configurations may exploit this flaw via crafted requests to gain unauthorized access to protected network resources.

Impact

Successful exploitation allows an authenticated attacker to bypass identity-based firewall policies enforced through FSSO, potentially accessing network segments or resources beyond their authorized scope. This undermines the integrity of role-based access controls and network segmentation enforced by the FortiGate.

PoC

```
Installed version : 7.2.10
Fixed version      : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4.10 or above with FSSO TS Agent version 5.0 build 0324 and later.

11	Fortinet FortiGate – Insertion of Sensitive 2FA Information in Logs and Debug Command (FG-IR-24452)	Medium
----	---	--------

Description

The installed version of FortiOS is affected by an Insertion of Sensitive Information into Log File vulnerability (CWE-532), tracked as CVE-2025-31514. This flaw may allow an attacker with at least read-only privileges to retrieve sensitive two-factor authentication (2FA) information by reviewing system logs or executing the diagnose CLI command.

Impact

Exposure of 2FA-related data through logs reduces the effectiveness of multi-factor authentication as a security control, potentially enabling a low-privileged or compromised account to capture authentication secrets and facilitate unauthorized access to systems otherwise protected by 2FA.

PoC

```

Installed version : 7.2.10
Fixed version      : See vendor advisory
  
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.6.4 or above. The system can be upgraded to FortiOS 7.6.4. Please note if upgrading be caution on the services that are currently running in the environment.

12	Fortinet FortiGate – Insufficient Session Expiration in SSL-VPN (FG-IR-25-411)	Medium
----	--	--------

Description

The installed version of FortiOS is affected by an Insufficient Session Expiration vulnerability (CWE-613) in the SSL-VPN component, tracked as CVE-2025-62631. Under specific conditions, an active SSL-VPN session may not be terminated following a user password change, potentially allowing continued unauthorized access to network resources.

Impact

Failure to invalidate sessions upon credential change may allow an attacker who has obtained a valid session to maintain persistent access to protected network resources even after the compromised credentials have been reset, undermining a primary remediation action taken during a security incident.

PoC

```
Installed version : 7.2.10
Fixed version      : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4.1 or above. The system can be upgraded to FortiOS 7.4.1. Please note if upgrading be caution on the services that are currently running in the environment.

13	Fortinet FortiGate – LDAP Cleartext Credentials Retrievable via IP Modification (FG-IR-24-111)	Medium
----	---	---------------

Description

The installed version of FortiOS is affected by an Insufficiently Protected Credentials vulnerability (CWE-522), tracked as CVE-2024-32122. A privileged authenticated attacker may retrieve LDAP credentials in cleartext by modifying the configured LDAP server IP address in FortiOS to redirect authentication traffic to an attacker-controlled server.

Impact

Successful exploitation could allow an attacker with administrative access to intercept and recover LDAP credentials in cleartext, potentially compromising directory services authentication and enabling lateral movement across systems that rely on the same credential store.

PoC

```
Installed version : 7.2.10
Fixed version    : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4.9 or above. The system can be upgraded to FortiOS 7.4.9. Please note if upgrading be caution on the services that are currently running in the environment.

14 Fortinet FortiGate – Path Traversal in CLI (FG-IR-26-122)

Medium

Description

The installed version of FortiOS is affected by a Path Traversal vulnerability (CWE-22) in the CLI component, tracked as CVE-2025-61624. An authenticated attacker with an admin profile and at least read-write permissions may exploit this flaw via specially crafted CLI commands to write or delete arbitrary files outside the intended directory scope on the affected device.

Impact

Successful exploitation could allow an attacker to tamper with or destroy critical system and configuration files, potentially leading to device misconfiguration, service disruption, or complete loss of system integrity. This vulnerability has been confirmed exploited in the wild, significantly elevating remediation urgency.

PoC

```
Installed version : 7.2.10  
Fixed version    : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.6.5 or above. The system can be upgraded to FortiOS 7.6.5. Please note if upgrading be caution on the services that are currently running in the environment.

15	Fortinet FortiGate – Privilege Escalation in Automation Stitch (FG-IR-24-385)	Medium
----	---	--------

Description

The installed version of FortiOS is affected by an Authentication Bypass Using an Alternate Path or Channel vulnerability (CWE-288) in the Automation Stitch component, tracked as CVE-2025-22862. An authenticated attacker may exploit insufficient authorization validation in the Webhook action handler to escalate their privileges beyond those assigned to their account.

Impact

Successful exploitation could allow a low-privileged authenticated user to gain elevated or administrative control over the FortiGate device, bypassing role-based access controls enforced at the management layer. This poses a significant risk to the integrity of security policy management, particularly in environments where multiple administrative roles are defined.

PoC

```
Installed version : 7.2.10
Fixed version    : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.2.12 or above. The system can be upgraded to FortiOS 7.2.12. Please note if upgrading be caution on the services that are currently running in the environment.

16	Fortinet FortiGate – SSL-VPN Symmlink Persistence Patch Bypass (FG-IR-25-934)	Medium
----	---	--------

Description

The installed version of FortiOS is affected by an Exposure of Sensitive Information vulnerability (CWE-200), tracked as CVE-2025-68686, which bypasses Fortinet's previously issued patch for the SSL-VPN symbolic link persistence mechanism. A remote unauthenticated attacker can exploit a double-slash path manipulation in crafted HTTP requests to circumvent the patch's string-matching check, restoring unauthorized read-only access to the root filesystem — provided the device has been previously compromised at the filesystem level via a separate vulnerability.

Impact

Successful exploitation allows an attacker who has already established a foothold on the device to maintain persistent, unauthorized access to the root filesystem through the SSL-VPN interface, effectively rendering prior patch remediation incomplete. This significantly elevates the risk on devices previously exposed to CVE-2022-42475, CVE-2023-27997, or CVE-2024-21762, as it re-enables the attacker's persistence mechanism and continued access to sensitive system files and credentials.

PoC

```
Installed version : 7.2.10
Fixed version    : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4.7 or above. The system can be upgraded to FortiOS 7.4.7. Please note if upgrading be caution on the services that are currently running in the environment.

17	Fortinet FortiGate – Open Redirect and Reflected XSS in Web Filter Warning Page (FG-IR-24-542)	Medium
Description		

The installed version of FortiOS is affected by two vulnerabilities in the Web Filter warning page component under advisory FG-IR-24-542. CVE-2025-47890 (CWE-601) allows an unauthenticated remote attacker to perform open redirect attacks via crafted HTTP requests, while CVE-2025-31366 (CWE-79) enables an unauthenticated attacker to execute reflected Cross-Site Scripting (XSS) attacks through unsanitized input injected into the warning page response.

Impact

Exploitation of CVE-2025-47890 may allow an attacker to redirect end users from a trusted FortiGate-hosted URL to a malicious site, facilitating phishing or credential harvesting campaigns. CVE-2025-31366 may enable script injection into the victim's browser session, potentially leading to session token theft, credential exposure, or unauthorized actions performed in the context of the authenticated user.

PoC

```

Installed version : 7.2.10
Fixed version      : See vendor advisory
  
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4.9 or above. The system can be upgraded to FortiOS 7.4.9. Please note if upgrading be caution on the services that are currently running in the environment.

01	Fortinet FortiGate – Unchecked Return Value Leading to Null Pointer Dereference in FortiOS API (FG-IR-25-653)	Low
----	--	------------

Description

The installed version of FortiOS is affected by an Unchecked Return Value vulnerability (CWE-252) in the FortiOS API, tracked as CVE-2025-58903. An authenticated attacker with high-level privileges may submit a specially crafted API request that triggers a Null Pointer Dereference, causing the HTTP daemon to crash and resulting in a Denial of Service (DoS) condition.

Impact

Successful exploitation disrupts the FortiOS HTTP daemon, temporarily interrupting management API availability and potentially affecting web-based administrative access to the device. While confined to availability impact with no confidentiality or integrity risk, repeated exploitation could impair operational continuity and administrative responsiveness of the firewall.

PoC

```
Installed version : 7.2.10
Fixed version      : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4.9 or above. The system can be upgraded to FortiOS 7.4.9. Please note if upgrading be caution on the services that are currently running in the environment.

02 Fortinet FortiGate – SSH Key Added Despite Aborted Operation (FG-IR-23-008)

Medium

Description

The installed version of FortiOS is affected by an Incomplete Cleanup vulnerability (CWE-459), tracked as CVE-2023-29184. When an SSH key addition operation is aborted via the CLI, the key is silently retained on the system due to improper cleanup handling, allowing a VDOM-privileged attacker to covertly persist unauthorized SSH keys through crafted CLI requests.

Impact

Successful exploitation allows a VDOM-privileged attacker to silently establish persistent SSH access to the device without the operation appearing as a completed configuration change, effectively bypassing standard audit and change-detection controls and creating a covert persistence mechanism on the firewall.

PoC

```
Installed version : 7.2.10
Fixed version      : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4 or above. The system can be upgraded to FortiOS 7.4. Please note if upgrading be caution on the services that are currently running in the environment.

03 Fortinet FortiGate Trusted hosts bypass via SSH (FG-IR-25-545)

Low

Description

The installed version of FortiOS is affected by an Improper Privilege Management vulnerability (CWE-269), tracked as CVE-2025-54821. This flaw may allow an authenticated administrator to bypass configured trusted host restrictions through a specially crafted CLI command.

Impact

Exploitation could allow an authenticated administrator to circumvent trusted host access controls, undermining a key network-level safeguard intended to restrict management access to approved source addresses.

PoC

```
Installed version : 7.2.10  
Fixed version    : See vendor advisory
```

Remediation

Fortinet has recommended upgrading to the fixed OS versions 7.4.12 or above. The system can be upgraded to FortiOS 7.4.12. Please note if upgrading be caution on the services that are currently running in the environment.

2.11 Host by Compliances

01 Ensure intra-zone traffic is not always allowed

Failed

Description

Ensure that only specific, authorized traffic is allowed between networks in the same zone. This adds an extra layer of protection between different networks.

Impact

Increase the risk of lateral movement, enabling attackers or malware to spread more easily between systems if a device is compromised. Additionally, it reduces the effectiveness of network segmentation and makes it more difficult to enforce the principle of least privilege. It is recommended to restrict intra-zone traffic and allow only explicitly authorized communication through firewall policies based on business requirements.

Remediation

In CLI:

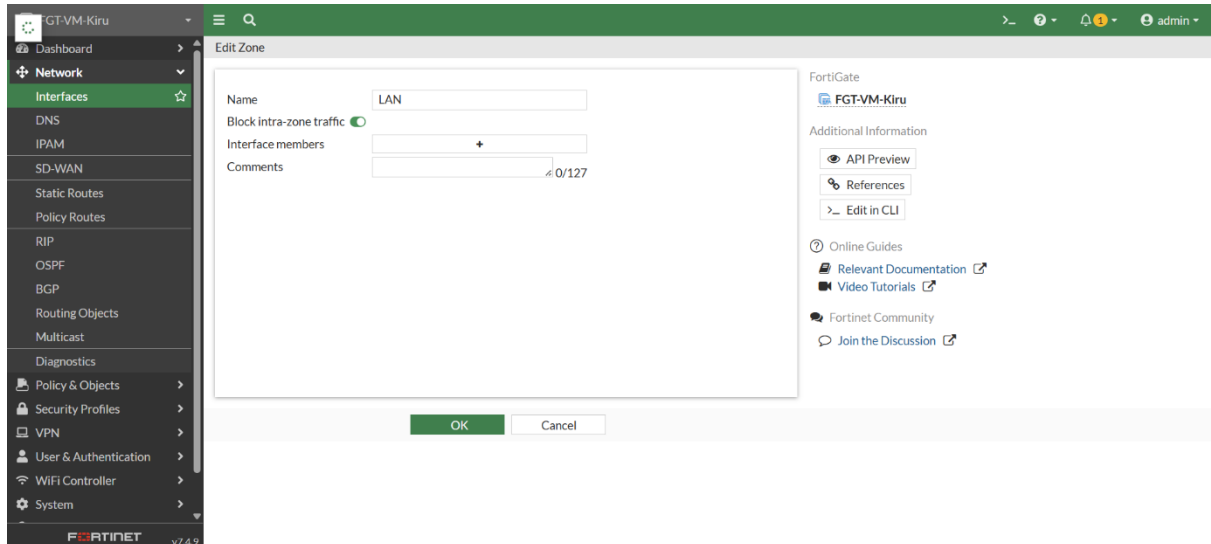
1. Enter the configuration mode using **config system zone**.
2. Enter the specific zone to edit using **edit <Zone_name>**.
3. Run the command **set intrazone deny**.

```
CLI Console (1)
FGT-VM-Kiru # config system zone
FGT-VM-Kiru (zone) # show
config system zone
    edit "LAN"
    next
end
FGT-VM-Kiru (zone) # edit "LAN"
FGT-VM-Kiru (LAN) # set intrazone deny
FGT-VM-Kiru (LAN) # end
```

4. Save the configuration using **end** command.

In GUI:

Go to **Network** -> **Interfaces**, select the zone and click on **Edit** and turn on **Block intrazone traffic**.



02 Disable all management related services on WAN port

Failed

Description

The WAN interface was found to have management related services enabled and accessible. These services are intended for administrative access and should only be reachable via a dedicated management interface, not exposed on the internet-facing WAN interface.

Impact

Exposing management services on the WAN interface significantly increases the firewall's attack surface, as it allows these services to be reached directly from the internet.

Remediation

On CLI:

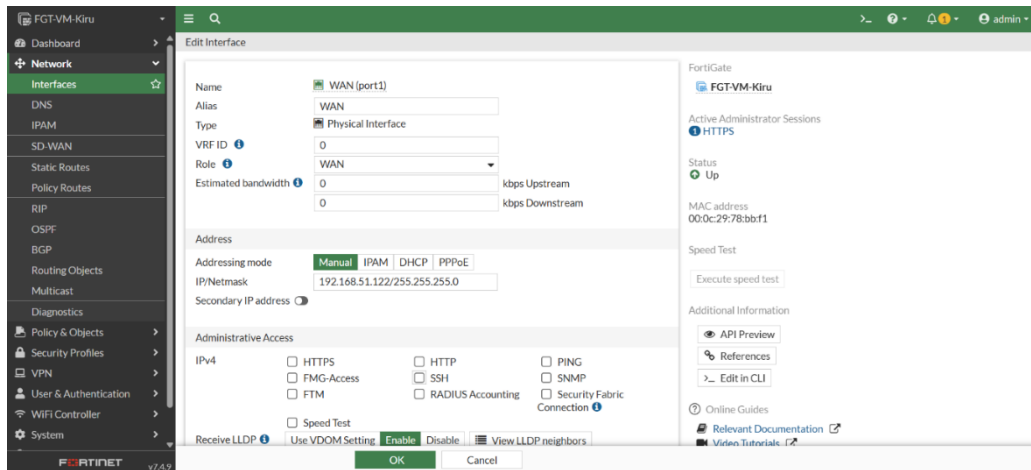
1. Enter the configuration mode using **config system interface**.
Run the command **edit <WAN_interface>**.
2. Run the command **unset allowaccess ping**.
3. Save the configuration using **end** command.

CLI Console (1)

```
FGT-VM-Kiru # config system interface
FGT-VM-Kiru (interface) # edit "port1"
FGT-VM-Kiru (port1) # unset allowaccess ping
```

On GUI:

1. Go to **Network > Interfaces**
2. Review the WAN Interface and disable Ping access.



03 Ensure 'Pre-Login Banner' is set

Failed

Description

Configure a pre-login banner which at minimum should prohibit unauthorized access, provide notice of logging and monitoring and avoid using the word 'welcome' or similar words of invitation

Impact

Login Banners warn any intruders who may want to access FortiGate that some activities are illegal and advise the authorized and legitimate users on acceptable use.

Remediation

In CLI:

1. Enter the configuration mode.
2. Run the command **set pre-login-banner enable** to enable the pre-login banner.

```
FGT01 # config system global
FGT01 (global) # set pre-login-banner enable
FGT01 (global) # end
```

3. Save the configuration using **end** command.

In GUI:

1. Go to **System > Replacement Messages > Extended View > Pre-Login Disclaimer Message**.

Name	Description	Modified
Admin		
Post-login Disclaimer Message	Replacement message for post-login disclaimer	
Pre-login Disclaimer Message	Replacement message for pre-login disclaimer	
Alert E-mail		
Block Message	Alert email text for block incidents	
Critical Event Message	Alert email text for critical event notification	
Disk Full Message	Alert email text for disk full events	
Intrusion Message	Alert email text for IPS events	
Virus Message	Alert email text for virus incidents	
Authentication		
Authentication Rejection Page	Replacement HTML for authentication rejection page	
Authentication Success Page	Replacement HTML for authentication success page	

2. You can use the pre-defined banner or enter a customized banner.
3. Click **Save**.

Pre-login Disclaimer Message

Message Format: text/plain Message Size: 703 B/32.6 kB

PRE WARNING:
This is a private computer system. Unauthorized access or use is prohibited and subject to prosecution and/or disciplinary action. Any use of this system constitutes consent to monitoring at all times and users are not entitled to any expectation of privacy. If monitoring reveals possible evidence of violation of criminal statutes, this evidence and any other related information, including identification information about the user, may be provided to law enforcement officials. If monitoring reveals violations of security regulations or unauthorized use, employees who violate security regulations or make unauthorized use of this system are subject to appropriate disciplinary action.

RESTORE DEFAULTS Save CANCEL

04 Ensure 'Post-Login-Banner' is set

Failed

Description

Sets the banner after the user is logged into the system successfully. This is equivalent to Message of the Day (MOTD) in other systems.

Impact

Without a post-login banner, the organization loses a key legal safeguard that reinforces user awareness of monitoring, consent to log retrieval, and limited privacy expectations on the network. This weakens its ability to demonstrate proper notice was given, potentially affecting its legal standing in the event of a security incident or access dispute.

Remediation

In CLI:

1. Enter the config mode.
2. Run the command **set post-login-banner enable** to enable the post login banner.
3. Save the configuration using **end** command

```
FGT01 # config system global
FGT01 (global) # set post-login-banner enable
FGT01 (global) # end
```

05 Ensure timezone is properly configured

Failed

Description

The FortiGate firewall's system time zone was found to be incorrectly configured, not aligned with the organization's actual location or operational needs, affecting the accuracy of displayed and logged timestamps.

Impact

Incorrect time zone configuration can lead to misleading timestamps, affecting certificate validity checks, log correlation across Syslog and SNMP systems, and the reliability of scheduling, logging, and SSL-dependent features in FortiOS — all of which can complicate incident investigation and forensic analysis.

Remediation

In CLI:

1. Enter the configuration mode using **config system global**.
2. Set the timezone using the command **set timezone <timezone>**.
3. Save the configuration using **end** command.

CLI Console (1)

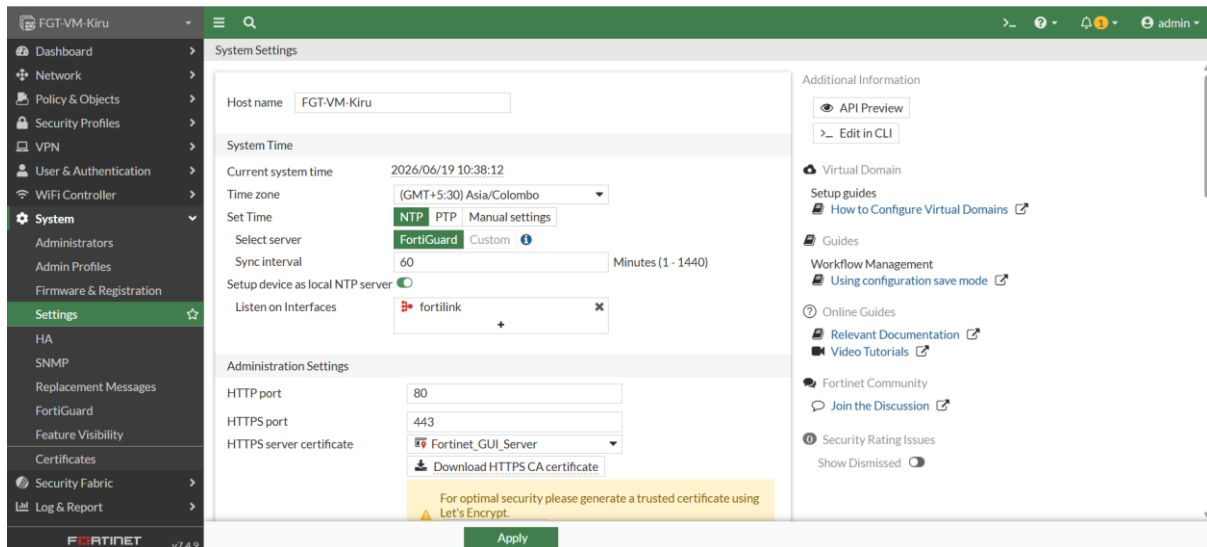
```
FGT-VM-Kiru # config system global
FGT-VM-Kiru (global) # set timezone "Asia/Colombo"
```

CLI Console (1)

```
FGT-VM-Kiru # config system global
FGT-VM-Kiru (global) # get | grep timezone
timezone                : Asia/Colombo
FGT-VM-Kiru (global) #
```

In GUI:

1. Go to **System > Settings**.
2. Select the correct timezone under **System Time**.



Note: Enter the appropriate timezone. The presented is an example.

06 Ensure correct system time is configured through NTP

Failed

Description

The FortiGate firewall was found without a custom NTP configuration using redundant primary and secondary servers. As a result, system time may rely on manual settings or a single/default source, increasing the risk of time drift and reducing redundancy if an NTP server becomes unavailable.

Impact

Without proper NTP synchronization, the device's clock may drift over time, reducing the reliability of log correlation and complicating troubleshooting, auditing, and forensic investigation. It can also affect certificate validity checks, as well as scheduling rules and other time-sensitive or SSL-dependent features. The absence of a secondary NTP server further removes redundancy, leaving the device without a reliable time reference if the primary source fails.

Remediation

In CLI:

1. Enter the configuration mode using **config system ntp**.
2. Run the following commands to setup a NTP server:

```
CLI Console (1)
FGT-VM-Kiru # config system ntp
FGT-VM-Kiru (ntp) # set type custom
FGT-VM-Kiru (ntp) # config ntpserver
FGT-VM-Kiru (ntpserver) # edit 1
new entry '1' added
FGT-VM-Kiru (1) # set server "Enter IP Address"
```

07**Disable USB Firmware and configuration installation****Failed****Description**

The FortiGate firewall was found with USB port auto-install enabled for both configuration and firmware, allowing the device to automatically load a configuration file or firmware image from a connected USB drive without requiring administrative authentication or approval.

Impact

This exposes the device to unauthorized or unintended changes, as an attacker with physical access or a malicious insider could connect a USB drive with a manipulated configuration or compromised firmware image, which would load automatically without credentials. This could lead to unauthorized configuration changes, backdoored firmware, denial of service, or complete compromise of the firewall bypassing standard administrative controls entirely.

Remediation**In CLI:**

1. Enter the config mode using **config system auto-install**.
2. Type the commands **set auto-install-config disable** and **set auto-install-image disable** commands to disable USB firmware and configuration installation.
3. Save the configuration using **end** command.

```
FGT01 #  
FGT01 # config system auto-install  
  
FGT01 (auto-install) # set auto-install-config disable  
  
FGT01 (auto-install) # set auto-install-image disable  
  
FGT01 (auto-install) # end
```

08 Disable static keys for TLS

Failed

Description

The FortiGate firewall was found to have support for static SSL/TLS key ciphers enabled. This setting allows TLS sessions terminating on the device to negotiate cipher suites that rely on static keys rather than ephemeral key exchange mechanisms.

Impact

Allowing static key ciphers for TLS sessions weakens the cryptographic security of encrypted communications terminating on the firewall. Static keys do not provide forward secrecy, meaning that if a static private key is ever compromised, an attacker who has previously captured encrypted traffic could decrypt all past sessions that used that key. This significantly increases the impact of a key compromise and reduces the overall resilience of the device's TLS implementation against modern cryptographic attacks.

Remediation

In CLI:

1. Enter the config mode using **config system global** command.
2. Enter the command **set ssl-static-key-ciphers disable**.
3. Save the configuration using **end** command.

```
FGT01 # config system global
FGT01 (global) # set ssl-static-key-ciphers disable
FGT01 (global) # end
```

09

Ensure management GUI listens on secure TLS version**Failed****Description**

The FortiGate firewall's management GUI was found to permit administrative HTTPS access using outdated or weaker TLS versions, rather than being restricted to TLS 1.3, the most secure version currently supported for SSL-encrypted administrator access.

Impact

Allowing administrative GUI access over older TLS versions exposes the management interface to weaker cryptographic protections, increasing the risk of Man-in-the-Middle (MitM) attacks. Older TLS versions may contain known protocol-level weaknesses or support deprecated cipher suites, which could allow an attacker positioned on the network path to intercept, downgrade, or tamper with administrative sessions, potentially exposing credentials or session data used to manage the firewall.

Remediation**In CLI:**

1. Enter the config mode using **config system global**.
2. Enter the command **set admin-https-ssl-version tlsv1-3** to set the TLS version to 1.3.
3. Save the configuration using **end** command.

CLI Console (1) 

FortiGate-60E # config system global

FortiGate-60E (global) # set admin-https-ssl-version tlsv1-3

FortiGate-60E (global) # end

10 Ensure single CPU core overloaded event is logged

Failed

Description

The FortiGate firewall does not have single CPU core monitoring logging enabled. The "log-single-cpu-high" option under config system global is not configured, preventing detection of individual CPU core overload conditions while overall CPU usage remains low. This creates a monitoring gap where performance degradation may go unidentified.

Impact

Without single CPU core logging enabled, instances of individual core overload are not detected or logged, as firewall dashboards display only aggregate CPU metrics. This can result in undiagnosed performance issues, including traffic processing delays or interruptions, without clear visibility into the root cause. The lack of these logs further impairs troubleshooting and performance analysis when such issues occur.

Remediation

In CLI:

1. Enter the configuration mode using **config system global**.
2. Run the command **set log-single-cpu-high enable** to enable logging CPU core monitoring.
3. Save the configuration using **end**.

CLI Console (1)

```
FGT-VM-Kiru # config system global
FGT-VM-Kiru (global) # set log-single-cpu-high enable
FGT-VM-Kiru (global) # end
```

11 Ensure 'Password Policy' is enabled

Failed

Description

The FortiGate firewall does not have password policy enabled. Without this setting, administrative and IPsec pre-shared key passwords are not subject to minimum length or complexity requirements, leaving accounts vulnerable to weak credential selection and brute force attacks.

Impact

Weak passwords significantly increase the risk of unauthorized account compromise through brute force or dictionary attacks. An attacker gaining administrative access to the FortiGate can modify critical firewall settings, including security policies, access controls, and configurations, directly compromising network security and data protection.

Remediation

In CLI:

1. Enter the config mode using **config system password-policy**.
2. Enter the following commands in the configuration mode to enable a password policy to the FortiGate device.

```
CLI Console (1)
FGT-VM-Kiru # config system password-policy
FGT-VM-Kiru (password-policy) # set status enable
FGT-VM-Kiru (password-policy) # set apply-to admin-password ipsec-preshared-key
FGT-VM-Kiru (password-policy) # set minimum-length 12
FGT-VM-Kiru (password-policy) # set min-lower-case-letter 1
FGT-VM-Kiru (password-policy) # set min-upper-case-letter 1
FGT-VM-Kiru (password-policy) # set min-non-alphanumeric 1
FGT-VM-Kiru (password-policy) # set expire-status enable
FGT-VM-Kiru (password-policy) # set expire-day 90
FGT-VM-Kiru (password-policy) # set reuse-password disable
FGT-VM-Kiru (password-policy) # end
```

3. Save the configuration using **end** command.

12

Virtual patching on the local-in management interface**Failed****Description**

The FortiGate firewall does not have virtual patching enabled on local-in policies for the management interface. Without this configuration, IPS signatures are not applied to traffic destined to the GUI and SSH management access, leaving these critical interfaces vulnerable to known exploits during the patch deployment window.

Impact

Unprotected management interfaces are exposed to exploitation of known vulnerabilities before patches are applied and deployed. Attackers can leverage publicized exploits against GUI and SSH access to compromise the firewall's administrative functions, bypassing the need for valid credentials and gaining unauthorized control over device configuration and security posture.

Remediation**In CLI:**

Run the following commands to enable virtual patching on the local-in management interface.

1. Enter the configuration mode using **config firewall local-in-policy**
2. Select the respective local-in policy id using the command **edit <id>**.
3. Run the following commands to enable virtual patching on the local-in policy.

set action accept

set virtual-patch enable

4. Save the configuration using the **end** command.

```
CLI Console (1)
FGT-VM-Kiru # config firewall local-in-policy
FGT-VM-Kiru (local-in-policy) # edit 1
new entry '1' added

FGT-VM-Kiru (1) # set action accept
FGT-VM-Kiru (1) # set virtual-patch enable
FGT-VM-Kiru (1) #
```

13 Ensure that policies do not use "ALL" as Service

Failed

Description

The FortiGate firewall policies are configured to permit "ALL" services. This overly permissive configuration does not explicitly define which protocols and services are authorized, allowing unintended traffic types to traverse the firewall without clear visibility or control.

Impact

Policies using "ALL" services create excessive protocol exposure and obscure actual traffic flows permitted through the firewall. This can allow unauthorized or potentially malicious protocols to pass undetected, expanding the attack surface and compromising the firewall's ability to enforce granular service-level access controls.

Remediation

In CLI:

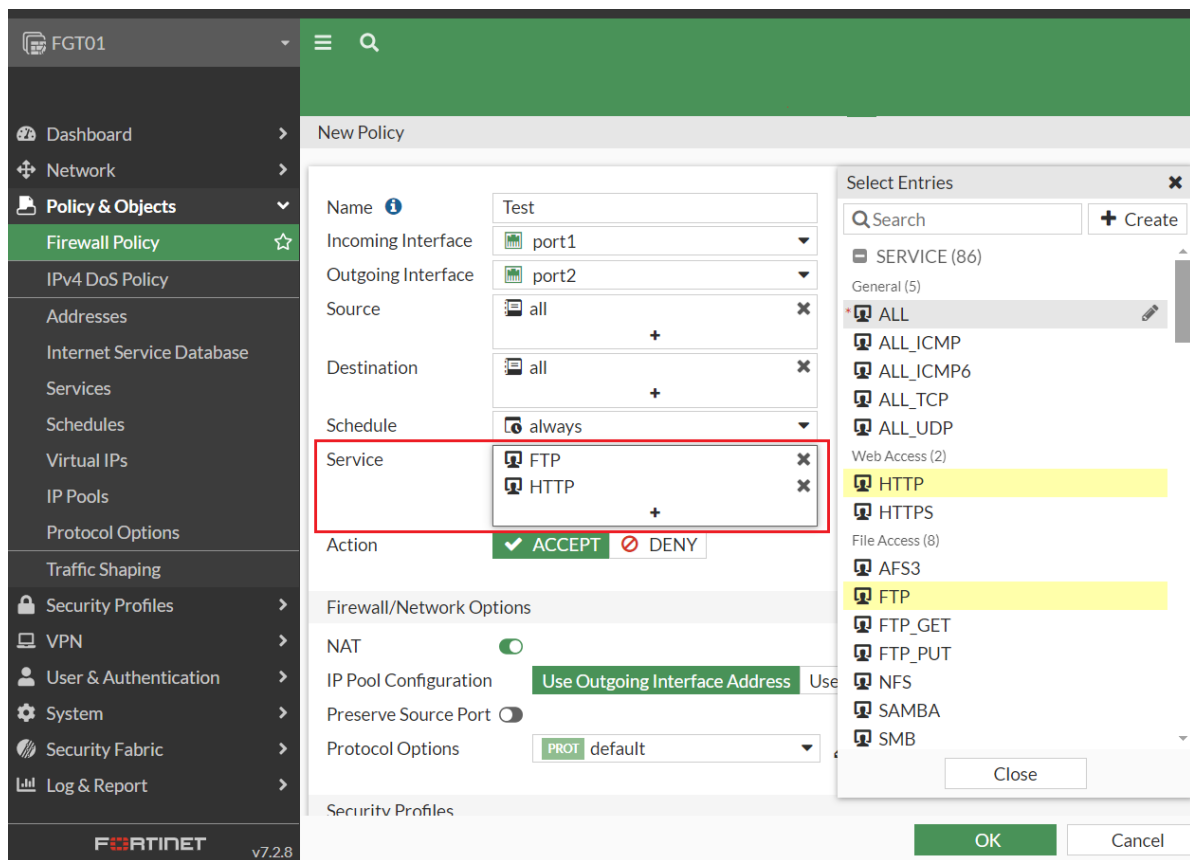
1. Enter the configuration mode using **config firewall policy**.
2. Select the Policy ID by running the command **edit 2**.
3. Select the required services the policy should use by running the command, **set service FTP SNMP**.
4. Save the configuration using the **end** command.

CLI Console (1)

```
FGT-VM-Kiru # config firewall policy
FGT-VM-Kiru (policy) # edit 2
FGT-VM-Kiru (2) # set service "FTP" "SNMP"
```

In GUI:

1. Go to **Policy & Objects**.
2. Click on **Firewall Policy**.
3. Select the policy, click **Edit**.
4. In the Service section, click on it and select **FTP and SNMP** (Any appropriate service).
5. Click **OK**.



14 Ensure logging is enabled on all firewall policies

Failed

Description

Logging is not enabled on one or more firewall policies. Firewall policy logging records details of network traffic that is permitted or denied by the firewall and provides visibility into communication occurring across the network. Enabling logging on all firewall policies helps maintain an audit trail of security-relevant events, supports incident detection and investigation, and facilitates compliance with organizational and regulatory requirements.

Impact

Failure to enable logging on all firewall policies can reduce visibility into network traffic and security events. This may hinder the organization's ability to detect malicious activity, investigate security incidents, perform forensic analysis, and demonstrate compliance with security policies and regulatory requirements. In the event of a security breach, the absence of logs may limit the ability to determine the scope, source, and impact of the incident, potentially increasing recovery time and overall business risk.

Remediation

Enable logging on the firewall policies, 199 and 200.

In GUI (for denied policies):

1. Select the Policy that requires enabling logging.
2. Enable the option "**Log Violation Traffic**".

Edit Policy

Incoming Interface

☐

any

Outgoing Interface

☐

any

Source

all

+

Destination

Blockchain-Crypto.Mining.Pool

Botnet-C&C.Server

Malicious-Malicious.Server

Phishing-Phishing.Server

Proxy-Proxy.Server

Spam-Spamming.Server

Tor-Relay.Node

VPN-Anonymous.VPN

+

Schedule

always

Action

ACCEPT

DENY

Log Violation Traffic

Comments

Write a comment...

0/1023

15 Enable Outbreak Prevention Database**Failed****Description**

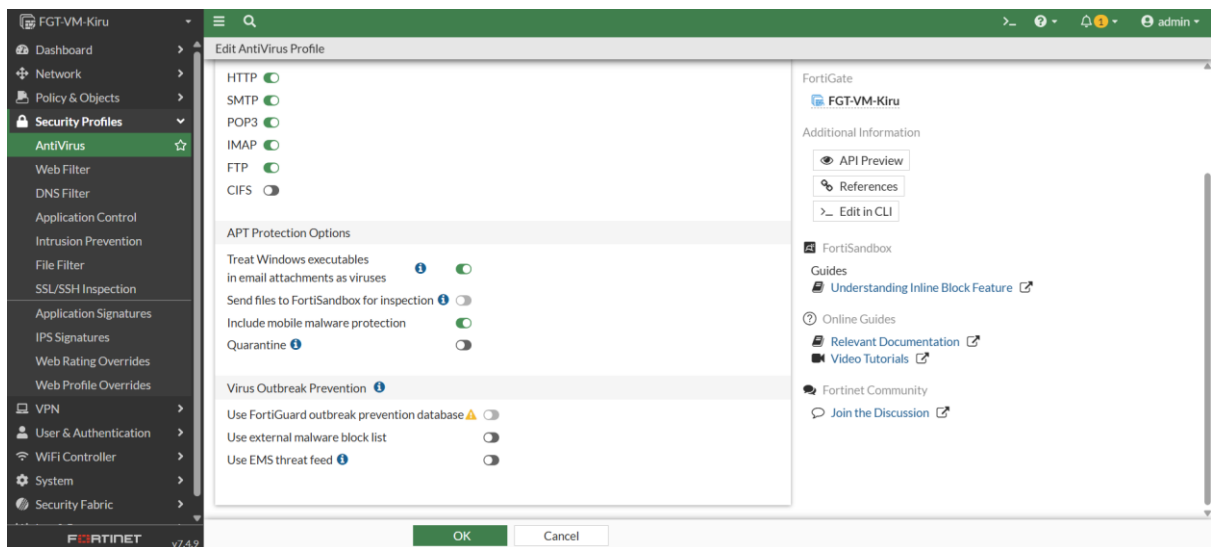
The FortiGate antivirus security profiles do not have the FortiGuard outbreak prevention database enabled. Without this setting, antivirus inspection relies solely on signature-based detection, missing an additional protective layer using hash-based threat intelligence from FortiGuard's Global Threat Intelligence database.

Impact

The disabled outbreak prevention database limits malware detection to signature-based detection alone, reducing effectiveness against new or emerging threats not yet in the signature database. The absence of hash-based detection from FortiGuard significantly weakens the organization's ability to identify zero-day malware variants and newly identified malicious files, increasing the risk of undetected malware infections.

Remediation**In GUI:**

1. Go to **Security Profiles > AntiVirus**.
2. Select the relevant Security Profile.
3. Go to **Virus Outbreak Prevention** section and enable the option **Use FortiGuard outbreak prevention database**.
4. Click **OK**.



16

Ensure inline scanning with FortiGuard AI-Based Sandbox Service is enabled**Failed****Description**

The FortiGate firewall does not have inline scanning with the FortiGuard AI-Based Sandbox Service (FAIS) enabled, leaving malware detection reliant on signature-based methods alone rather than cloud-based behavioral analysis.

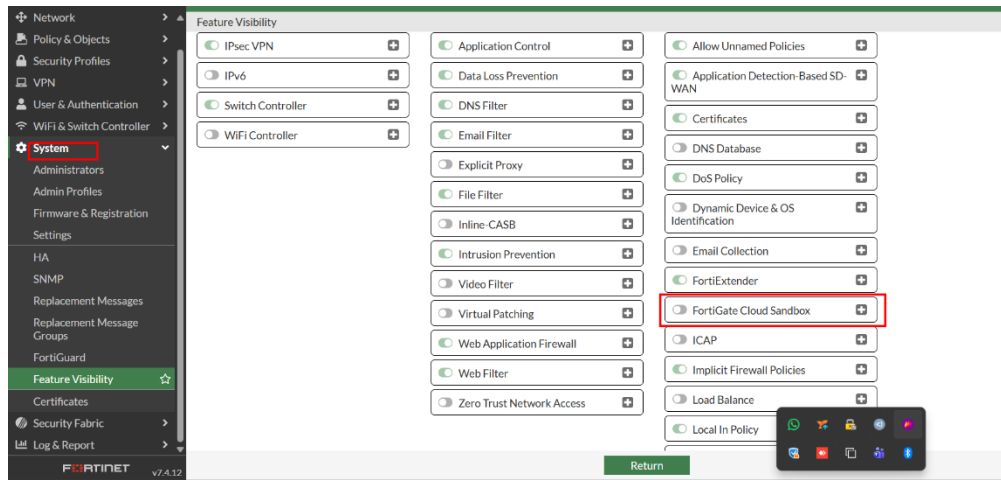
Impact

Without inline sandboxing, unknown and zero-day malware can bypass antivirus inspection undetected, increasing the risk of initial compromise and delaying identification of an outbreak's source. This significantly weakens the organization's defense against emerging threats.

Remediation**In GUI:**

1. Enable the FortiGate Cloud feature visibility using **System > Feature Visibility**.
2. In the **Additional Features** section, enable **FortiGate Cloud Sandbox**.
3. Click **Apply**.
4. Configure the Cloud Sandbox Fabric connector using **Security Fabric > Fabric Connectors** and double-click the **Cloud Sandbox** card.
5. Set the Type to FortiGate Cloud.
6. Select a Region.
7. Enable Inline scan.
8. Click OK.
9. Configure the antivirus profile using **Security Profiles > AntiVirus**.
10. Click **Create New**.
11. Set the **Feature set** to **Proxy-based**.
12. Enable the protocols to inspect.
13. Enable **Send files to FortiSandbox for inspection**.
14. Set the Scan strategy to Inline, and set the Action to Block.

15. Click **OK**.



17

Enable CDR for proxy mode on XLSB, OpenOffice, and RTF files**Failed****Description**

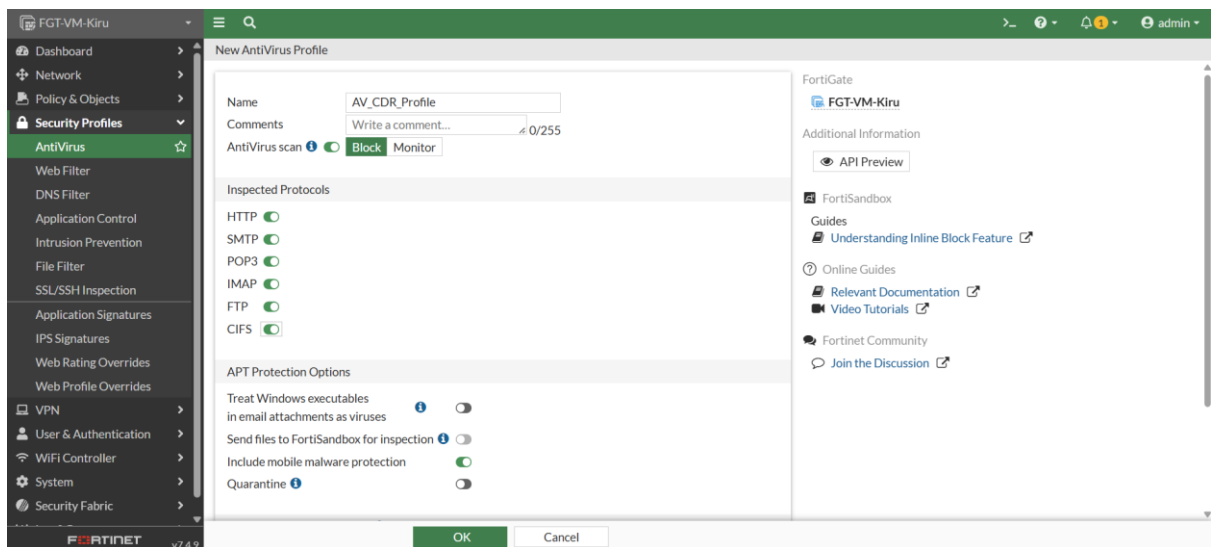
The FortiGate antivirus security profiles do not have Content Disarm & Reconstruction (CDR) enabled for proxy mode inspection of XLSB, OpenOffice, and RTF files. Without this setting, potentially malicious content embedded in these document formats is not sanitized before reaching end users.

Impact

Disabled CDR for office document formats allows malicious payloads embedded in XLSB, OpenOffice, and RTF files to bypass traditional antivirus detection. This increases the risk of document-based malware delivery, leading to potential system compromise, data exfiltration, or advanced persistent threat infections through weaponized office documents.

Remediation**In GUI:**

1. Go to **Security Profiles > AntiVirus** and click **Create New**.
2. Enable AntiVirus scan, and select Block.
3. Set Feature set to **Proxy-based**.
4. Under Inspected Protocols, enable one or more protocols that support proxy-based antivirus scanning.
5. Under APT Protection Options, enable **Content Disarm and Reconstruction**, and select **Apply CDR** to office files to disarm Microsoft Office and OpenOffice files, including RTF (Rich Text Format) and XLSB (Excel Binary Workbook) files.



18 Ensure DNS Filter logs all DNS queries and responses**Failed****Description**

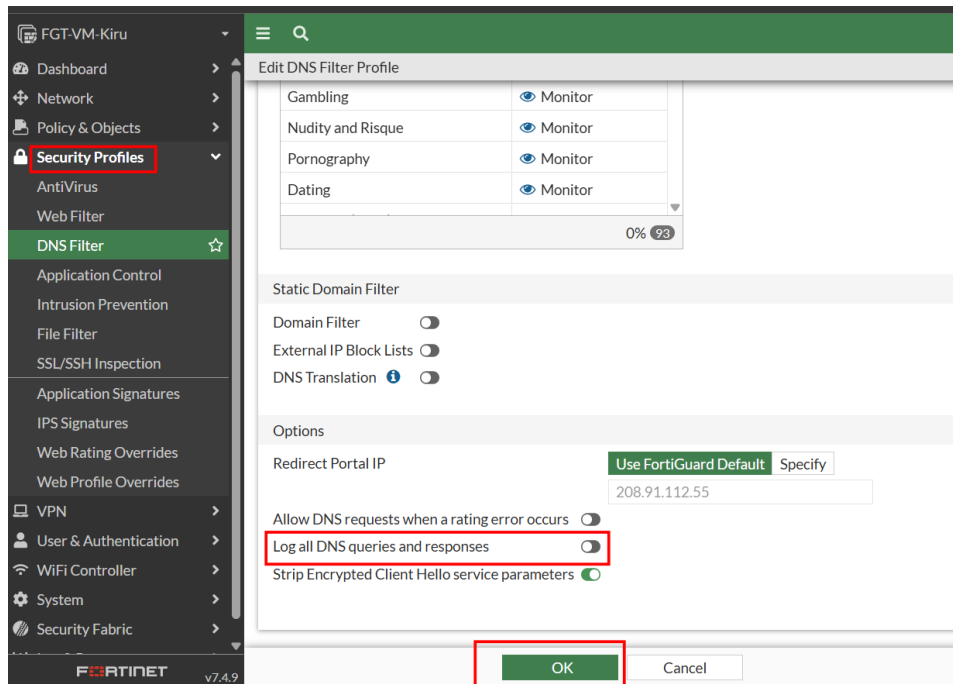
The FortiGate DNS filter security profiles do not have comprehensive logging enabled for all DNS queries and responses. By default, allowed DNS traffic is not logged, creating visibility gaps for blocked, monitored, and permitted DNS activities.

Impact

Without DNS query and response logging, organizations lack complete visibility into DNS-based threats and network activity patterns. This creates critical data gaps in threat hunting and incident response, limiting the ability to identify malicious domain resolution attempts, detect DNS tunneling, or investigate potential data exfiltration activities.

Remediation**In GUI:**

1. Go to **Security Profiles > DNS Filter**.
2. Select the DNS Filter Profile to be edited.
3. Under the **Options** section, enable the option **Log all DNS Queries and Responses**.
4. Click **OK**.



19 Block applications running on non-default ports

Failed

Description

The FortiGate Application Control security profiles do not have enforcement of default application ports enabled. The "Block applications detected on non-default ports" option is not configured, allowing applications to run and communicate on non-standard ports without restriction or detection.

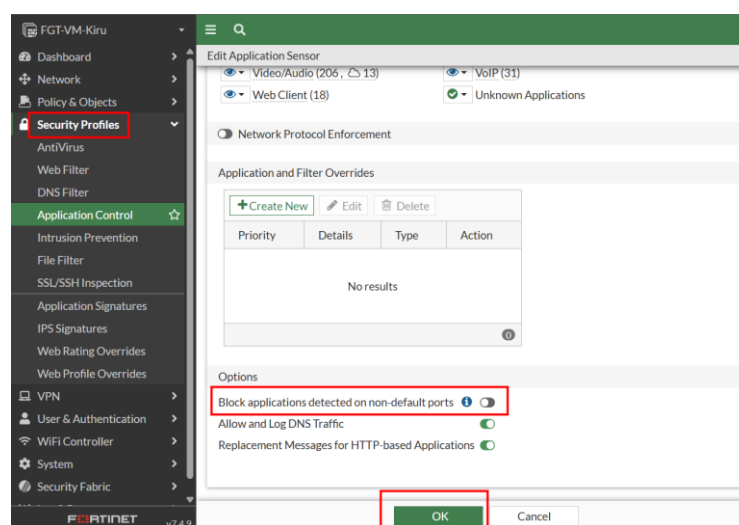
Impact

Without blocking applications on non-default ports, attackers can use alternative port assignments to evade detection and establish unauthorized communication channels. Applications such as rogue HTTPS servers on non-standard ports can facilitate data exfiltration, command-and-control communications, and lateral movement within the network without triggering application-level security controls.

Remediation

In GUI:

1. Go to **Security Profiles > Application Control**.
2. Select relevant App Control profile.
3. Enable **Block applications detected on non-default ports** option.



In CLI:

1. Enter the configuration mode using **config application list**.
2. Run the command **edit <profile name>** to edit the relevant profile name.
3. Run the command **set enforce-default-app-port enable** to block applications detected on non-default ports.
4. Run **end** to save the configuration.

CLI Console (1)

```
FGT-VM-Kiru # config application list
```

```
FGT-VM-Kiru (list) # edit default
```

```
FGT-VM-Kiru (default) # set enforce-default-app-port [ ]
```

20 Ensure all Application Control related traffic is logged**Failed****Description**

The FortiGate Application Control security profiles have categories configured with the "Allow" action. When categories are set to "Allow", including "Unknown Applications", the associated traffic is not logged, creating visibility gaps for application-level security monitoring.

Impact

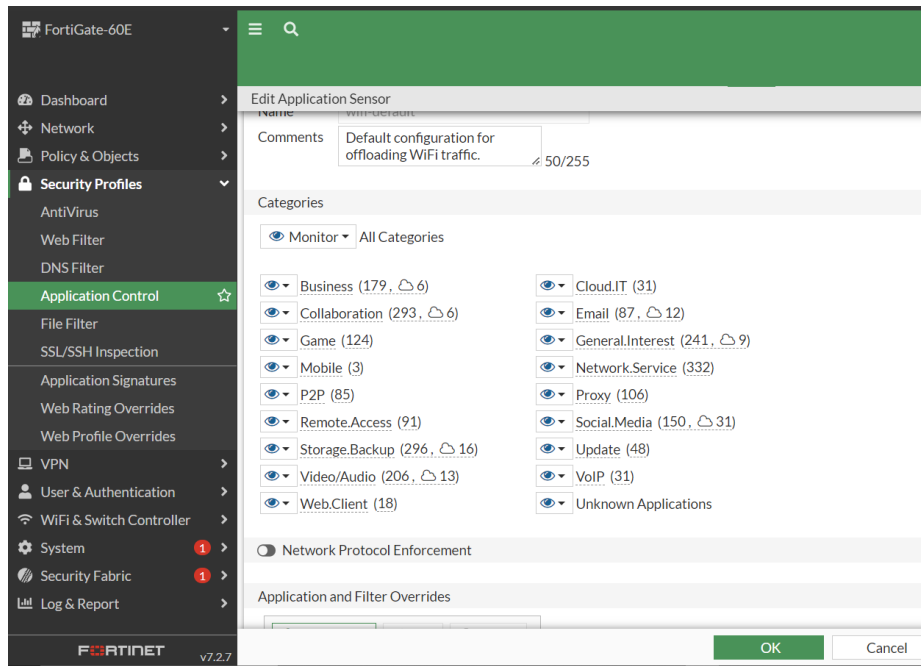
Unlogged allowed traffic prevents visibility into application behavior and usage patterns, hindering security investigation and threat analysis. This visibility gap limits the ability to detect anomalous application behavior, identify policy violations, or reconstruct incident timelines during forensic investigations and incident response activities.

Remediation

All categories in "wifi-default" is set to Allowed. Change it to action "Monitor" by following the steps given below.

In GUI:

1. Go to **Security Profiles > Application Control**.
2. Select the relevant App Control profile.
3. Change any categories with '**Allow**' action to '**Monitor**' and Click **OK**.



21 Enable Compromised Host Quarantine

Failed

Description

The FortiGate Security Fabric automation for compromised host quarantine is not enabled. The default automation stitch to quarantine high severity compromised hosts detected by FortiClient EMS, FortiAPs, and FortiSwitches is disabled, preventing automated isolation of infected endpoints.

Impact

Without a compromised host quarantine automation enabled, infected endpoints detected by security sensors remain connected to the network, enabling lateral movement and continued threat propagation. The lack of automated isolation requires manual intervention for containment, increasing incident response time and the window of exposure for data exfiltration and network compromise.

Remediation

In CLI:

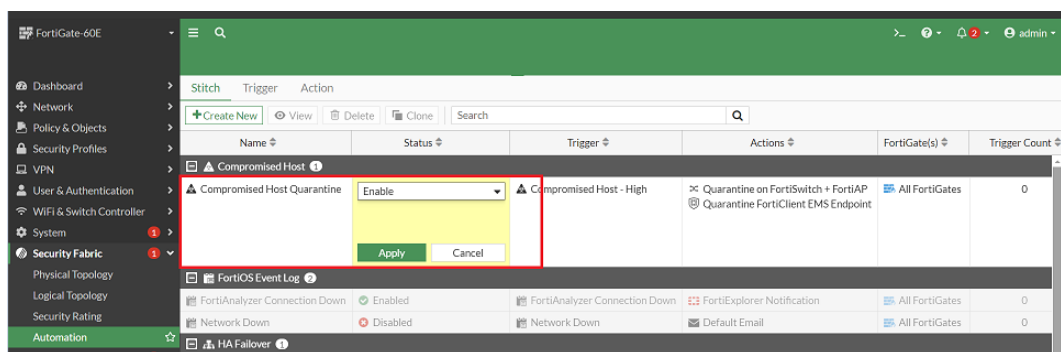
1. Enter the configuration mode.
2. Run the following commands.

```
FortiGate-60E # config system automation-stitch
FortiGate-60E (automation-stitch) # edit Compromised\ Host\ Quarantine
FortiGate-60E (Compromised Host~ine) # set status enable
```

3. Save the configuration using the **end** command.

In GUI:

1. Go to **Security Fabric > Automation**.
2. Select **Compromised Host Quarantine**.
3. Edit and change **Disable** to **Enable**.



4. Click **Apply**.

22 Centralized Logging and Reporting

Failed

Description

The FortiGate device is not configured to send logs to a centralized collection point. Syslog logging to a remote server such as a SIEM, FortiAnalyzer, or FortiManager is not configured, limiting log retention and visibility across the infrastructure.

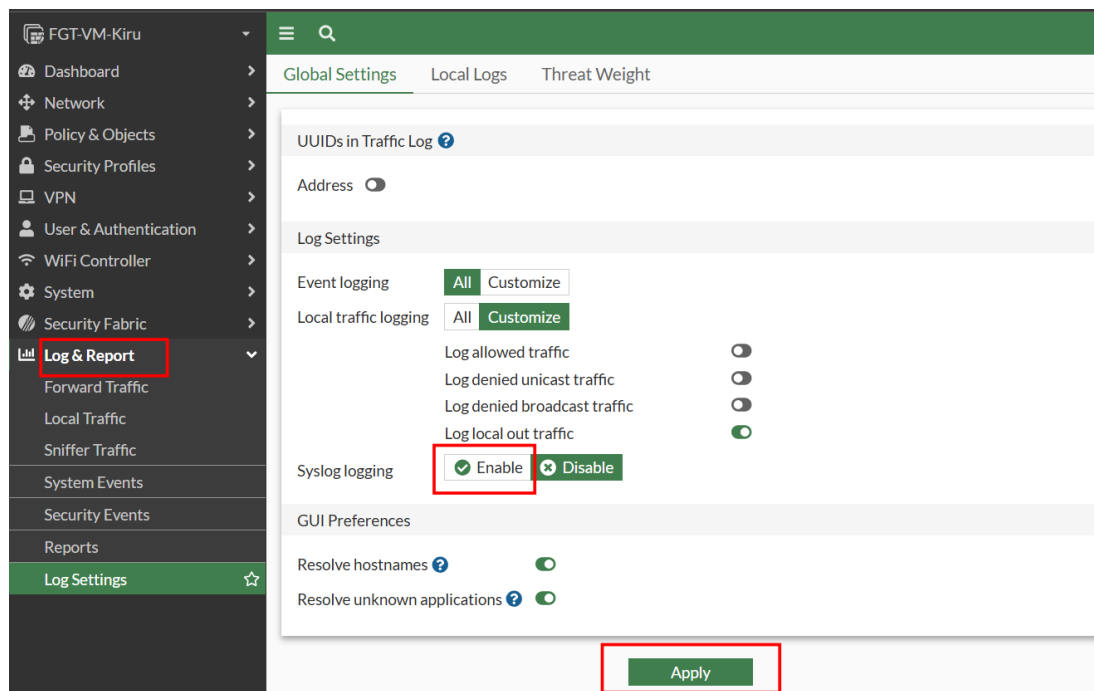
Impact

Without centralized logging, device logs are retained only on local storage with limited retention periods. This restricts log availability for security investigations, compliance reporting, and forensic analysis. Loss of local logs during device failure or compromise eliminates audit trails, and fragmented logging across devices prevents event correlation and visibility into sophisticated multi-stage attacks.

Remediation

In GUI:

1. Go to **Log & Report > Log Settings**.
2. Under **Syslog logging** configure a remote server to send logs to and click **Apply**.



3 Document Acceptance Certificate

Name of the Project: North Sails Vulnerability Assessment and Config Audit Report – UK Portsmouth Firewall

Customer: North Sails PVT

Service Integrator: N*Able (Pvt) Ltd | No. 36, Bristol Street, Colombo 01.

Site Location: UK Portsmouth

Project Start Date:

Project End Date:

(Customer Name)

Name:	
Title:	
Signature:	
Date:	

Name:	
Title:	
Signature:	
Date:	

N*Able (PVT) Ltd

Name:	Prabuddha Deshan
Title:	Lead Engineer - InfoSec
Signature:	
Date:	

Name:	Sisira Dharmakeerthi
Title:	Technical Project Manager
Signature:	
Date:	

Remarks: